Engineering *Digest*

April 10–17, 2026 | Weekly Edition | Issue #6 | 18 min read

THIS WEEK'S BRIEFING

167

Vulnerabilities patched by Microsoft in a single Patch Tuesday — double March's count, with two zero-days actively exploited in the wild

IN THIS ISSUE

- Security: April Patch Tuesday mega-month + Fortinet zero-days
- Quick Take: CircleCI report — AI writes faster, teams ship slower
- Leadership Read: Thoughtworks on the delivery pipeline bottleneck
- Quick Take: Bluesky's double outage — port exhaustion, then DDoS
- Feature: GitHub Copilot data training — April 24 deadline
- Outside In: Revolut launches AI financial assistant

April's Patch Tuesday was the busiest in memory — 167 Microsoft vulnerabilities, a Fortinet zero-day already under active exploitation before its advisory even published, and a SAP SQL injection scoring 9.9 CVSS sitting quietly in financial planning systems across the sector. Meanwhile, a new CircleCI report confirms what many engineering leaders have quietly suspected: AI is making code generation faster but delivery pipelines haven't kept pace, and the gap is widening. This issue maps both pressures.

PRIORITY 0 — ONGOING

AWS Middle East degraded — Day 47+ DEGRADED

Apr 17	ME-CENTRAL-1 (UAE) and ME-SOUTH-1 (Bahrain) remain degraded. No recovery timeline published.
Mar 15	AWS acknowledges ongoing geopolitical threat environment affecting regional data centre operations.
Mar 1	Initial degradation reported across multiple services in both Middle East regions.

As of April 17, no restoration timeline has been communicated. Teams operating in UAE and Bahrain AWS regions should assume continued degradation. AWS Health Dashboard →

QUOTE OF THE WEEK

"It has reached a level of fervor akin to a religion. If you ask anyone today, 'What AI tool would you choose if given just one?' the answer would invariably be Claude."

— Arvind Jain, CEO of Glean, speaking at HumanX, April 11, 2026

THE WEEK AT A GLANCE

Eight stories in sixty seconds

Action required

Security **Fortinet zero-day under active exploitation.** CVE-2026-35616 (CVSS 9.1) in FortiClient EMS enables unauthenticated RCE. CISA added to KEV; federal agencies given April 9 deadline. Second FortiClient EMS zero-day in weeks. *BleepingComputer →*

Security **SAP SQL injection scores 9.9 CVSS.** CVE-2026-27681 affects BW/BPC financial planning systems — an authenticated low-privilege user can read, modify, or delete database data. Patch Tuesday scope extends well beyond Microsoft. *BleepingComputer →*

Data policy **GitHub Copilot data training opt-out window closes April 24.** Free, Pro, and Pro+ users will have interaction data used for AI training by default from that date. Business and Enterprise users are covered by DPA. *GitHub Changelog →*

Worth knowing

Infra

Bluesky hit by two major outages in ten days. April 10: port exhaustion; April 16: DDoS attack still being mitigated. The platform's infrastructure is being stress-tested at a pace its original architecture wasn't designed for. *Bluesky Blog →*

Delivery

CircleCI: main-branch success rates at a five-year low. 70.8% success rate on main, against a 90% benchmark. The report recorded its largest-ever throughput surge year-on-year, but median team performance declined. AI is accelerating code generation faster than teams can integrate it. *CircleCI →*

AI

Revolut launches "AI by Revolut" assistant. Spending insights, investment updates, trip planning — built-in and live from April 9. Fintech's AI arms race moves from back-end optimisation to customer-facing financial command centres. *City AM →*

Watching

Fintech

Monzo exits the US for the second time, refocusing on UK and European markets. *FinTech Futures →*

AI

JetBrains Air enters public preview. Agentic dev environment orchestrating Codex, Claude, Gemini, and Junie concurrently. Worth watching to see whether multi-agent orchestration delivers in practice. *JetBrains →*

SECURITY & COMPLIANCE

When Everything Patches at Once

167	9.9	9.1	2×
Microsoft CVEs patched	SAP BW/BPC CVSS score	Fortinet EMS CVSS score	March's patch volume

At 10am Tuesday, Microsoft pushed fixes for 167 vulnerabilities — double the count from March and the highest single-month tally in recent memory. But the headline number is

almost beside the point. Among them were two zero-days already exploited in the wild, seven critical remote code execution flaws, and a collection of patches that extended across SAP, Adobe, and Fortinet — each carrying its own severity, urgency, and remediation window. For engineering teams supporting banking and fintech infrastructure, April's Patch Tuesday arrived less as a routine update cycle and more as a simultaneous crisis across multiple vendor ecosystems.

The Microsoft layer

Of those CVEs, eight were rated Critical — seven enabling remote code execution, one denial of service. The two actively exploited zero-days are CVE-2026-32201, a SharePoint spoofing vulnerability (CVSS 6.5) already being used in targeted attacks, and a second flaw affecting Windows components. Seven critical RCE vulnerabilities across a single patch batch represents a significant exposure window for any organisation running unpatched systems across the standard 30-day remediation cycle.

> *"The cumulative burden of April's patch cycle falls on the same security teams already managing Fortinet advisories, SAP critical updates, and an active KEV entry — simultaneously."*
>
> — Engineering Digest editorial synthesis

Fortinet: exploited before the advisory

The Fortinet disclosure is the most operationally urgent element of this month's cycle. CVE-2026-35616 in FortiClient EMS allows unauthenticated remote code execution — an attacker with no credentials can gain control of systems running the affected versions. CISA moved it to the Known Exploited Vulnerabilities catalogue immediately and gave US federal agencies an April 9 deadline. The advisory was published after the vulnerability was already

FORTICLIENT EMS CONTEXT

CVE-2026-35616 is the second critical FortiClient EMS zero-day in consecutive months — CVE-2026-21643 preceded it. Both scored 9.1 CVSS. CISA has added both to its Known Exploited Vulnerabilities catalogue.

FortiSandbox also carries a separate authentication bypass (CVE-2026-39813, CVSS 9.1) in the same advisory batch.

under active exploitation, meaning organisations relying on advisory-triggered patch cycles had no protection window at all.

The pattern here — two critical FortiClient EMS zero-days in consecutive months — warrants architectural scrutiny, not just patching. Security teams with Fortinet products in their network perimeter are managing a compound risk: known CVEs, an active threat actor, and a second advisory cycle before the first remediation is fully validated across the estate.

SAP: the financial system exposure

SAP's contribution to April's patch load is significant for banking and fintech specifically. CVE-2026-27681 is a SQL injection flaw in SAP BW/BPC — the financial planning and consolidation product used heavily across large financial institutions. A CVSS of 9.9 reflects the severity: an authenticated user with low privileges can read, modify, or delete database contents. The second SAP flaw, CVE-2026-34256 (CVSS 7.1), allows an authorised user to overwrite executable ABAP reports in ERP and S/4HANA systems. Both are less glamorous than the Fortinet zero-day but potentially more damaging in a regulated financial environment where data integrity is both a technical and compliance obligation.

KEY TAKEAWAYS

→ April's patch cycle spans four major vendors simultaneously — Microsoft, Fortinet, SAP, Adobe — each requiring independent prioritisation and validation tracks

→ The Fortinet EMS zero-day was exploited before its advisory published, making advisory-triggered remediation cycles structurally insufficient for this class of threat

→ SAP BW/BPC exposure (CVSS 9.9) has direct implications for financial data integrity in regulated environments — a compliance angle, not just a security one

Sources: BleepingComputer (Apr 15), The Hacker News (Apr 15), BleepingComputer / Fortinet (Apr 14), Pathlock (Apr 14)

QUICK TAKES

Two stories worth knowing

Operational resilience

Engineering leadership

2

Major outages in 10 days

Bluesky's infrastructure stress test

Two major outages in ten days have put Bluesky's infrastructure under uncomfortable scrutiny. April 10 brought a port exhaustion failure — the platform ran out of available network connections under traffic load, a classic scaling failure mode where system design meets unexpected demand. A detailed post-mortem followed. Six days later, on April 16, a DDoS attack took services down again, still being mitigated as of April 17. The company confirmed no unauthorised access to private user data.

Port exhaustion is an instructive failure pattern. It surfaces when connection handling hasn't been designed for the traffic volume a system now receives — no single component breaks, but the aggregate runs out of a resource that was never expected to be a constraint. For a platform growing rapidly as an alternative to X, hitting this failure mode reveals the gap between original architecture assumptions and current operating scale.

−7%

Median team main-branch throughput, despite 59% average growth

AI writes faster. Teams ship slower.

"The delivery pipeline has become the binding constraint on engineering performance" — that's Thoughtworks' read on the CircleCI 2026 State of Software Delivery report, which analysed 28 million CI workflows. The aggregate numbers look strong: average throughput up 59% year-on-year, the biggest increase ever recorded. But the aggregate hides a structural split. The top 5% of teams nearly doubled their throughput (97% increase). The median team saw main-branch throughput decline 7%, even as feature branch activity grew 15%. The bottom 25% recorded no increase at all.

Main-branch success rates fell to 70.8% — the lowest in five years, against a 90% benchmark. Recovery times averaged 72 minutes, up 13% year-on-year. The picture that emerges is of AI accelerating code generation into pipelines that weren't built to handle the increased merge frequency and integration complexity. Fewer than 1 in 20 teams can currently ship at the pace AI tooling enables.

The takeaway: Two distinct failure modes in ten days — one architectural, one adversarial — raises real questions about whether Bluesky's infrastructure investment is keeping pace with its growth ambitions.

Sources: Bluesky Blog (Apr 17), Glitchwire (Apr 16)

The takeaway: AI coding tools are creating a delivery bottleneck — teams generating more code than their integration and validation pipelines can absorb, with the divergence growing wider between high-performing and median teams.

Source: CircleCI, 2026 State of Software Delivery (Feb 18)

DOWN THE RABBIT HOLE

PODCAST DHH spent years being publicly skeptical about AI coding tools. On the Pragmatic Engineer podcast (April 8, 1h 46m), he explains his complete reversal — now running an agent-first workflow with 100+ PRs in 90 minutes. The tension he describes maps directly onto the CircleCI data: writing code has never been faster, but the delivery and review infrastructure hasn't caught up.

Listen: "DHH's new way of writing code" — Pragmatic Engineer →

OTHER NEWS THIS WEEK

In Brief

Claude Mythos Preview announced. Anthropic's next model began rolling out to approximately 50 enterprise partners from April 7. Claude Code is now generating $2.5B+ in annualised revenue and has 1,000+ enterprise customers spending $1M+ annually, following the "Claude Mania" reception at HumanX on April 11. *CNBC →*

Pragmatic Engineer AI survey: cost concerns rising. 900+ responses show 15% of engineers flagging mounting costs and 30% hitting usage limits. Companies are footing the majority of AI tool spend, but

engineer and manager roles are converging in ways that complicate traditional reporting structures. *Pragmatic Engineer →*

UK fintech revenue approaching £34.7B. IBISWorld projects 12.1% growth in 2025–26, with open banking now serving 11 million active users in the UK. The regulatory sandbox framework continues to draw international fintech operations to London. *TechBullion →*

GitHub Copilot cloud agent: April updates. Pre-PR research and planning workflows, signed commits for agent-authored code, organisation-level firewall controls, mobile support (from April 8), and parallel validation delivering 20% faster builds. Claude Opus 4.7 now generally available on Copilot. *GitHub Changelog →*

FEATURE

The Copilot Data Decision Your Developers Haven't Made Yet

Starting April 24, GitHub will use interaction data from Copilot Free, Pro, and Pro+ accounts to train its AI models — by default, unless users opt out. That includes inputs, outputs, code snippets, and associated context from active sessions. The deadline is seven days away, and awareness among developer populations remains uneven.

What's included, what's protected

GitHub has been clear about the scope. Private repositories at rest are not included in training data. Copilot Business and Enterprise users are covered by their Data Processing Agreements — no change for them. The policy change applies to individual plan users: Free, Pro, and Pro+. Previously opted-out users retain their status; the change only applies to those who haven't made an active choice. Automated CI processes and bots using Copilot under individual accounts are subject to the same opt-out rules as human users — a detail likely to surprise teams running Copilot in pipeline automation.

The two-tier structure this creates

Individual Plans

Free · Pro · Pro+

- ✓ Inputs & outputs used for training
- ✓ Opt-out available (Settings → Copilot)
- ✓ CI bots on individual accounts included
- ⚠ Default: opted in from April 24

Business & Enterprise

Covered by DPA

- ✓ Private repos protected at rest
- ✓ No training data use under DPA
- ✓ No action required
- ● No change from April 24

Source: GitHub Changelog (Mar 25)

The practical consequence is a two-tier data relationship. Enterprise users have contractual protection — their code interactions stay outside GitHub's training corpus. Individual plan users on the same teams, or contractors and open-source contributors using personal accounts, do not. In environments where developers move between enterprise and personal tooling, the distinction matters. A developer testing something on a personal Pro account, or using a free account for side projects that touch work-adjacent code, is contributing training data that their employer has no visibility into.

Community response and the opt-out path

Developer community reaction on Reddit, LinkedIn, and technical forums has been sharply negative — primarily on the basis that opt-in should be the default for data use of this nature. GitHub's position is that individual users have agency via Settings → Copilot → Privacy, and that previously opted-out users are unaffected. That framing has not substantially quieted the backlash.

For engineering leaders, the practical question is whether the developer population under your oversight has the information to make an informed choice before April 24. Awareness campaigns, internal comms, or a team-level policy clarification are options that sit within reasonable scope. What happens after the deadline cannot be undone retroactively.

The broader pattern

GitHub's move is consistent with how AI model development at scale has to be funded — training data from real usage is the core economic model. The question for enterprises is whether the DPA boundary is robust enough, and whether the informal data leakage through individual accounts constitutes an acceptable risk. Both are assessments that require active decisions, not passive defaults.

The takeaway: Individual Copilot users become training data contributors by default from April 24 — enterprise plan protections do not extend to personal accounts, and the deadline applies even to CI bots running under individual credentials.

Sources: GitHub Changelog (Mar 25), WindowsForum (Apr 4), Open-TechStack (Apr 11)

THE LEADERSHIP READ

The Pipeline Is the Bottleneck

When CircleCI published its State of Software Delivery report in February, the headline narrative was AI acceleration. By March, Thoughtworks had published a sharper read: the data shows that AI coding tools have made the delivery pipeline — CI/CD, integration, review, validation — the primary constraint on engineering performance. Their analysis is worth sitting with carefully.

The finding that matters most

The CircleCI data shows record average throughput growth while median team main-branch throughput fell 7%. Thoughtworks' interpretation: high-performing teams have delivery pipelines strong enough to absorb the code volume AI tooling generates. Median and lower-quartile teams do not. The result is that AI amplifies existing delivery strengths rather than distributing capability improvements evenly. Teams with good pipelines get better. Teams without them get more code stuck in integration queues.

> *"Organizations that fail to recognize this will find that every dollar spent on AI coding tools produces diminishing returns."*
>
> — Thoughtworks, "A Thoughtworks perspective on CircleCI's 2026 State of Software Delivery," March 2026

What this means for investment decisions

The Thoughtworks piece makes a specific argument: organisations evaluating AI coding tool spend should assess their delivery pipeline before, not after, deployment. A team running 70% main-branch success rates and 72-minute average recovery times will generate more integration failures and slower throughput as AI tooling increases the volume of code entering that pipeline. The bottleneck doesn't disappear — it compounds.

The strategic framing for engineering leaders is that delivery infrastructure investment — pipeline reliability, test coverage, deployment automation — now has a quantifiable multiplier effect. AI tooling ROI depends on it. The 5% of teams approaching 97%

throughput growth are the ones whose delivery pipelines were already robust before AI tooling arrived.

Read the full piece: thoughtworks.com →

This could be worth talking about: *If your team's main-branch success rate is below 85%, do you know whether that's a pipeline capacity problem, a test coverage problem, or an integration process problem — and would adding AI coding tools make it better or worse?*

OUTSIDE IN

Revolut builds the financial command centre

From transaction processor to AI-native assistant

On April 9, Revolut launched "AI by Revolut" — a built-in financial assistant covering spending insights, investment updates, and trip planning. It arrives weeks after Starling's own AI assistant launch, built with Google Gemini. The timing is instructive: two of the UK's largest neobanks shipping customer-facing AI features within the same month signals a sector-wide phase change, from AI as back-end optimisation to AI as a primary customer interface.

> For fintech engineering teams, the competitive pressure here is specific: the expectation is no longer that AI features will arrive eventually, but that they ship concurrently with — or ahead of — competitors. Revolut and Starling have now set a public baseline for what an AI-native banking product looks like in the UK market.

What the engineering challenge looks like

Customer-facing financial AI assistants carry a different engineering burden than internal tooling. Accuracy requirements are heightened — an investment insight or spending summary presented directly to a retail customer carries regulatory exposure if it is wrong. The integration surface is large: transaction history, investment portfolio data, travel bookings, notifications. The latency and reliability expectations are those of a consumer product, not an internal dashboard.

Revolut's approach — building natively into the app rather than bolting on a third-party chat interface — suggests the engineering investment is structural rather than cosmetic. Whether that architectural decision pays off in reliability and personalisation quality will be visible in the product's performance over the next few quarters.

The takeaway: The UK fintech AI race has moved from model selection to product execution — with Revolut and Starling both shipping customer-facing AI financial assistants in the same month, engineering teams across the sector are now benchmarking against live products, not roadmaps.

Read the announcement: City AM →

ON THE RADAR

Coming Up

APR 20

ICDBIT 2026 — Manchester — International Conference on Data, Business, and Information Technology. icdbit.org →

APR 22

Fintech Summit Middle East — Dubai — Regional fintech leadership conference covering AI in financial services, open banking, and digital infrastructure. fintechsummitme.com →

APR 24

GitHub Copilot data training opt-out deadline — After this date, Free, Pro, and Pro+ interaction data used for AI training by default. Opt out: Settings → Copilot → Privacy. GitHub →

APR 30

Node.js 20 End of Life — Maintenance LTS support ends. Applications still running Node 20 will receive no further security patches after this date. Node 22 (LTS) is the migration target. nodejs.org →

RECOMMENDED READING

This Week's Links

A Thoughtworks perspective on CircleCI's 2026 State of Software Delivery thoughtworks.com

2026 State of Software Delivery — full report	circleci.com
DHH's new way of writing code (podcast, 1h 46m)	pragmaticengineer.com
SAP April 2026 Patch Day — full breakdown	pathlock.com

Engineering Digest

April 10–17, 2026 · Weekly Edition · Issue #6

Next edition: April 24, 2026

Archive

Issue 2.5 · Mar 27 · Weekly

Issue 3 · Apr 3 · Weekly

Issue 4 · Apr 10 · Deep Dive

Issue 5 · Apr 17 · Weekly

Issue 6 · Apr 17 · Weekly